TECHTALK WITH BILL | FREE CHECKLIST

Bank Heist Readiness Checklist

Four board questions and ten controls drawn from Bangladesh Bank, Bybit and the Texas laptop farms. By Bill Martin.

HOW TO USE THIS CHECKLIST

1. Pick one critical service that can move money, such as wire transfers or treasury payments.
2. Answer the four board questions for that service.
3. Score each of the ten controls: **Yes** (in place and tested), **Partly** (in place, not tested), or **No**.
4. Write a named owner and a due date next to every Partly or No.
5. Take the result to your next risk committee.

Every heist in the video borrowed trust instead of breaking a system. This checklist tests whether that trust is still deserved.

Part 1: The four board questions

Question	Your answer
What can we lose? The loss in dollars if this service is abused for one day.	
How likely is it? The rating on your risk heatmap, and why.	
Who owns it? One named person accountable for the service, its vendors and its AI.	
Can we prove the control works? The date each key control was last tested, and the result.	

If any answer is "we don't know," that is your first action.

Part 2: Ten controls

LESSON 1 | TRUSTED ACCESS

Bangladesh Bank, 2016

Attackers used the bank's own access to the SWIFT payment network to order close to one billion dollars in transfers. 81 million dollars got through.[3]

3. NPR Planet Money, Bangladesh Bank

#	Control	What good looks like	Score	Owner and date
1	**Payment system access is tightly held**	Few named accounts, multi factor sign in, separate admin and operator roles, access reviewed every quarter	Yes Partly No	
2	**High value payments are verified outside the system**	Large or unusual payments are confirmed on a separate channel, such as a call back to a known number, by someone other than the requester	Yes Partly No	
3	**Payments are monitored and reconciled every day**	Outgoing payment messages are matched to the core ledger daily, with alerts that reach a person outside business hours and on holidays	Yes Partly No	

LESSON 2 | A TRUSTED SCREEN FROM A TRUSTED VENDOR

Bybit, 2025

Attackers broke into a developer machine at Bybit's wallet software vendor and altered the approval screen. The signers approved what they saw, and 1.5 billion dollars was stolen.[4, 5]

4. FBI IC3, Bybit 5. NCC Group, Bybit technical analysis

#	Control	What good looks like	Score	Owner and date
4	**Approvers can verify what the screen shows**	Transaction details are checked on a second, independent device or system before a large approval is signed	Yes Partly No	
5	**Vendors in the payment path get deep due diligence**	Every vendor whose software touches payment approvals has a profile, a risk tier, an owner, and a review of how it builds and protects its code	Yes Partly No	
6	**Vendors are watched continuously, not once a year**	Independent cyber ratings, breach notification terms in the contract, and an alert when a vendor's risk rises	Yes Partly No	

LESSON 3 | TRUSTED PEOPLE

Texas laptop farms, 2026

North Korean operatives used false identities and AI deepfakes to get hired into remote jobs.[6] In September 2026 the FBI searched more than 40 Texas homes used as laptop farms for schemes affecting more than 70 U.S. companies.[1, 2]

1. U.S. Department of Justice, actions against North Korean remote IT worker schemes 2. U.S. Attorney's Office, Northern District of Texas, Operation Lonestar Roundup 6. U.S. State Department, alert on North Korean IT workers

#	Control	What good looks like	Score	Owner and date
7	**Remote hires prove who they are**	Live identity checks against official documents, video interviews with liveness checks, and the laptop shipped only to a verified address	Yes Partly No	
8	**Remote access is watched for warning signs**	Alerts for unexpected locations, remote control software, one person on several accounts, and devices that never move	Yes Partly No	

LESSON 4 | THE NEW SIGNER AND THE NEXT HEIST

AI agents and response speed

AI agents now review payments and recommend approvals. When a heist gets through anyway, speed of response decides how much is lost.

#	Control	What good looks like	Score	Owner and date
9	**Every AI agent that can move money is governed**	It is in the AI inventory with an owner and a risk rating, scored against the NIST AI Risk Management Framework, and tested against manipulated input data	Yes Partly No	
10	**The heist has been rehearsed**	A tabletop exercise of a fraudulent payment scenario run in the last 12 months, with a known recovery time for the payment service and an owner for every response task	Yes Partly No	

Part 3: Your result

Score	Meaning	Next step
9 or 10 Yes	Strong. Your trust is earned and proven.	Keep testing. Repeat this checklist every quarter.
6 to 8 Yes	Exposed in places.	Fix every No within 90 days, starting with the service with the highest dollar loss.
5 or fewer Yes	A borrowed trust heist is possible today.	Report to the board now, assign owners, and start with controls 2, 4 and 7.

Total Yes: _____ of 10

GO FURTHER

Want the slides, the banking cyber risk strategy and the risk and compliance architecture behind this checklist? Join the Banking Architect Office membership and send a request on the link. I will share access.
youtube.com/channel/UCMf7pje1x5iZkkEF-Y3PLSA/join

Sources

1. U.S. Department of Justice, actions against North Korean remote IT worker schemes
https://www.justice.gov/opa/pr/justice-department-announces-coordinated-actions-combat-north-korean-remote-it-worker

2. U.S. Attorney's Office, Northern District of Texas, Operation Lonestar Roundup
https://www.justice.gov/usao-ndtx/pr/operation-lonestar-roundup-dismantles-north-korean-it-worker-network-used-penetrate-us

3. NPR Planet Money, Bangladesh Bank
https://www.npr.org/transcripts/1079528331

4. FBI IC3, Bybit
https://www.ic3.gov/psa/2025/psa250226

5. NCC Group, Bybit technical analysis
https://www.nccgroup.com/research/in-depth-technical-analysis-of-the-bybit-hack/

6. U.S. State Department, alert on North Korean IT workers
https://www.state.gov/releases/office-of-the-spokesperson/2026/07/alert-to-countries-companies-and-other-entities-regarding-north-korean-it-workers/

7. Chainalysis, North Korea crypto theft in 2025
https://www.chainalysis.com/blog/crypto-hacking-stolen-funds-2026/